Shodan: el motor de búsqueda de dispositivos conectados a Internet
Laboratorio práctico y panorama agregado de Costa Rica

Alejandro Arias Rojas (C4C759) y Mariangel Arias Alfaro (C4C688)
Carrera de Informática Empresarial, Sede de Occidente, Universidad de Costa Rica
IF-6000 Redes en los Negocios
Profesor: Máster W. Mauricio Fernández Araya
29 de octubre de 2026

Shodan: el motor de búsqueda de dispositivos conectados a Internet

Introducción

Cuando se piensa en un buscador se piensa en páginas web, pero Internet también está hecha de routers, cámaras, servidores y equipos de gestión remota que responden a quien les toque la puerta. Shodan es un motor de búsqueda que indexa esos dispositivos y no las páginas: guarda la información pública que cada servicio expone, y permite consultarla con filtros (Shodan, s. f.-f). Esa capacidad sirve igual a quien defiende una red que a quien busca objetivos, por lo que entenderla es parte de la formación en redes y seguridad.

Este documento desarrolla el tema Shodan (práctico) del curso IF-6000 Redes en los Negocios. Cubre los siete puntos del temario: definición, importancia, características, funcionamiento, ejemplos prácticos, otros buscadores especializados e información adicional importante. La parte práctica se hizo con una cuenta académica gratuita, la interfaz web, la interfaz de línea de comandos (CLI) y la API oficial mediante un script propio en Python, y cada paso queda respaldado con capturas de pantalla.

Objetivo general

Explicar qué es Shodan, cómo funciona y qué se puede observar con él, demostrándolo con herramientas reales y de forma ética.

Objetivos específicos

1. Definir Shodan y describir su importancia, sus características y su funcionamiento con base en documentación oficial y fuentes académicas.
2. Operar Shodan desde la interfaz web, la CLI y la API, y documentar cada operación con evidencia propia.

3. Construir un panorama agregado de los servicios indexados en Costa Rica (country:CR) sin interactuar con ningún dispositivo.
4. Comparar Shodan con otros buscadores especializados y con GreyNoise, y probar esta última herramienta con consultas reales.
5. Establecer el marco ético y legal que delimita este tipo de trabajo en Costa Rica.

Alcance y declaración ética

Todo lo hecho es consulta pasiva al índice de Shodan. No se intentó conectarse a ningún dispositivo encontrado, no se probaron credenciales y no se escaneó ninguna dirección IP. Las estadísticas de Costa Rica se obtuvieron con consultas de conteo, que devuelven totales y rankings, no direcciones ni banners. Las capturas que mostraban datos de terceros (direcciones IP, nombres de dominio y de organizaciones) se difuminaron antes de incluirlas. Lo que el grupo probó se distingue de lo que solo investigó en la Tabla 1.

Tabla 1
Alcance real del trabajo: lo practicado frente a lo investigado

Componente	Practicado por el grupo	Solo investigado (fuentes)
Cuenta y créditos	Cuenta académica, panel de créditos y consumo (Figuras 2 y 3)	Reglas de consumo de créditos
Interfaz web	Búsquedas con country, port, product y ssl.cert.expired (Figuras 4, 8, 10 y 11)	Shodan Maps, Images, Monitor
CLI	info, count, stats con facets, host (Figuras 5 a 7 y 9)	Resto de subcomandos
API con Python	Script con count y facets, dashboard de 6 gráficos (Figuras 13 a 18)	Escaneos bajo demanda (scan)
Otros buscadores	GreyNoise Visualizer con dos consultas (Figuras 19 y 20)	Censys, ZoomEye y FOFA
IP propia	Consulta con la CLI: Shodan no tiene datos de esa IP (Figura 9)	Estudio de Bodenheim (2014) sobre indexación de equipos de prueba

Nota. Elaboración propia.

Definición

Shodan es un motor de búsqueda de dispositivos conectados a Internet. A diferencia de Google o Bing, que rastrean sitios web, Shodan rastrea equipos conectados directamente a la red, desde pequeñas computadoras de escritorio hasta centrales nucleares (Shodan, s. f.-f). La propia documentación los compara así: Shodan rastrea Internet, mientras que Google rastrea la World Wide Web. Su unidad básica de información es el banner: metadatos sobre el software que corre en un dispositivo, que pueden incluir, por ejemplo, el nombre y la versión del servidor o un mensaje de bienvenida (Shodan, s. f.-f).

Dicho de forma práctica, Shodan no indexa el contenido de un sitio sino la respuesta pública que da un servicio. Por eso una consulta como country:CR port:22 devuelve servicios SSH ubicados en Costa Rica, y no páginas que hablen de SSH.

Importancia

La documentación oficial menciona usos como seguridad de redes, investigación de mercado, evaluación de riesgo cibernético (incluida la exposición de proveedores), seguimiento de dispositivos del Internet de las cosas y medición del impacto del ransomware (Shodan, s. f.-f). Para un equipo de TI, el valor central es verse desde afuera: Shodan muestra lo que un tercero puede observar de una organización sin tocar sus sistemas.

El otro lado también existe. Bodenheim et al. (2014) evaluaron la capacidad de Shodan para localizar dispositivos de control industrial y advierten que puede servir a un atacante como herramienta de reconocimiento. Una tesis de maestría del Air Force Institute of Technology desplegó cuatro honeypots que imitaban controladores industriales durante 55 días, y todos quedaron indexados en la interfaz web en menos de 19 días; aun así, no observó un aumento de ataques dirigidos, de modo que concluyó que sus resultados no respaldan la idea de un uso

masivo de Shodan para atacar esos equipos (Bodenheim, 2014). Esa conclusión debe leerse con cautela, porque corresponde a un diseño experimental concreto.

En el contexto de Costa Rica la importancia se vuelve medible: en nuestra consulta del 27 de octubre de 2026, Shodan tenía indexados 292,152 servicios con country:CR (Figura 13). Cada uno es un servicio visible desde Internet, y la suma explica por qué ISP, empresas y universidades deberían revisar periódicamente qué muestran al exterior.

Características

Las características que se comprobaron o documentaron son las siguientes.

Búsqueda por filtros y facets

Las búsquedas se escriben como nombrefiltro:valor, sin espacio alrededor de los dos puntos, con comillas si el valor tiene espacios y combinando filtros con espacios (Shodan, s. f.-d). Los filtros existen para evitar falsos positivos; la propia documentación recuerda que buscar solo "Apache" puede traer resultados de una ciudad con ese nombre en lugar del servidor web. En la práctica usamos country, port, product, org, city y ssl.cert.expired. Los facets son rankings agregados de un campo sobre el conjunto de resultados, como los puertos más frecuentes, y son la base de nuestro panorama de Costa Rica.

Tres formas de acceso

Shodan se usa desde el sitio web, desde una CLI que se instala junto con la biblioteca de Python con pip install -U --user shodan y se configura con shodan init (Shodan, s. f.-c), y desde una API REST con endpoints para consultar un host, buscar, contar y solicitar escaneos (Shodan, s. f.-e). Las tres se usaron en este trabajo.

Sistema de créditos

Los créditos de consulta permiten descargar datos desde la web, la CLI o la API; un crédito permite descargar 100 resultados, se descuentan al usar un filtro o al pedir la página 2 en adelante, y se renuevan cada mes (Shodan, s. f.-b). Los créditos de escaneo permiten pedir escaneos de IP por la API, a razón de un crédito por IP (Shodan, s. f.-b). El endpoint de conteo (count) devuelve el total y los facets sin devolver resultados de hosts y, según la documentación, no consume créditos de consulta (Shodan, s. f.-e). Esto último lo verificamos: el panel mostraba 100 créditos antes y después de ejecutar el script (Figuras 3 y 12).

Plan académico

Registrarse con un correo académico permite acceder a un plan ampliado; la cuenta de este trabajo se creó con un correo institucional @ucr.ac.cr y el panel la muestra como Academic membership (Figura 2). La Tabla 2 resume lo que la documentación oficial indica para ese plan.

Tabla 2
Plan académico de Shodan según la documentación oficial

Aspecto	Qué indica la documentación
Requisito	Registrarse con un correo académico (por ejemplo .edu o .ac.uk); si no se reconoce, escribir a academic@shodan.io
Créditos mensuales	100 de consulta y 100 de escaneo
IPs monitoreadas	Hasta 16
Funciones incluidas	Shodan Maps, Shodan Images y filtro vuln en el sitio web
Limitaciones	No se pueden descargar datos desde el sitio web (solo CLI o API); el filtro vuln no funciona en CLI ni API; no se puede cambiar el correo

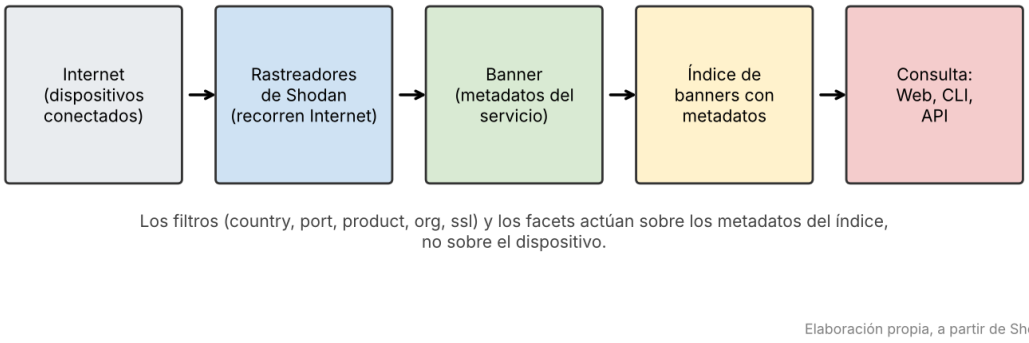
Nota. Elaboración propia a partir de Shodan (s. f.-a). Los planes y límites pueden cambiar; deben verificarse en la documentación vigente.

Funcionamiento

El flujo general se resume en la Figura 1. Shodan recorre Internet, recopila información de los dispositivos conectados directamente a ella y guarda la respuesta del servicio como banner, la ordena en un índice con metadatos (IP, puerto, producto, organización, ubicación,

certificado) y ofrece consultas sobre ese índice por web, CLI o API (Shodan, s. f.-f; Shodan, s. f.-d). Quien consulta nunca toca el dispositivo: consulta una copia de lo que el servicio respondió cuando Shodan lo visitó.

Figura 1
Flujo simplificado de funcionamiento de Shodan



Nota. Elaboración propia a partir de Shodan (s. f.-d, s. f.-f). La etapa de rastreo se describe de forma general porque la documentación consultada no detalla los rastreadores.

Esta naturaleza de copia implica tres consecuencias que verificamos o encontramos en las fuentes. Primera, el dato tiene fecha: cada resultado trae una marca de tiempo (Figuras 4 y 10) y los totales cambian de una consulta a otra porque el índice se actualiza de forma continua; el mismo día obtuvimos 292,118 con la CLI, 292,152 con el script y 293,085 en la web. Segunda, no todo servicio expuesto está indexado: la consulta de una IP propia del grupo respondió que no había información (Figura 9). Tercera, la cobertura y la actualidad dependen del motor; Durumeric et al. (2015) reportaron en su momento que en una prueba Shodan tardó 25 días en listar un servidor FTP nuevo, mientras que Censys lo mostró en menos de 48 horas, aunque advertimos que es una afirmación de los propios autores y de 2015.

Sobre quién escanea, Wu et al. (2024) estudiaron la operación de motores de búsqueda de dispositivos como Shodan y Censys, para lo cual desplegaron 28 honeypots durante un año, y

concluyeron que bloquear las IP de los escáneres o cambiar el puerto del servicio difícilmente evita ser escaneado. Esto matiza una idea común: cambiar un servicio de puerto no equivale a esconderlo.

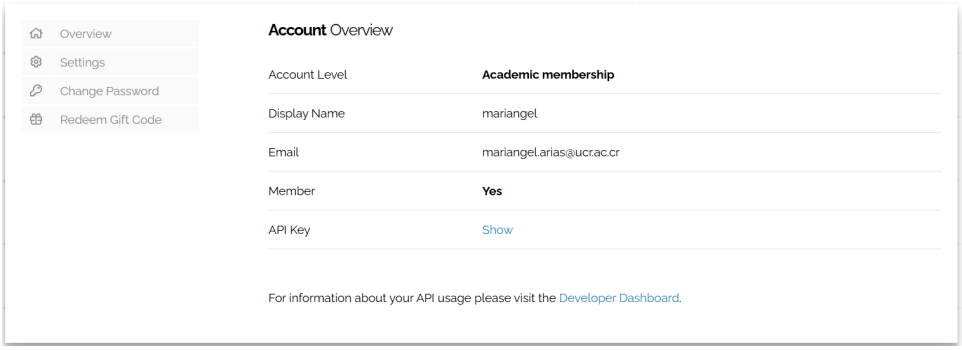
Ejemplos prácticos

Esta sección documenta lo realizado el 27 de octubre de 2026. Cada práctica indica objetivo, comando o filtro, resultado y conclusión.

Práctica 1: cuenta académica y panel de créditos

Objetivo. Confirmar que la cuenta académica gratuita está activa y conocer los créditos disponibles antes de consultar. **Resultado.** La cuenta aparece como Academic membership (Figura 2) y el panel de desarrollador muestra Membership API plan con 100 créditos de consulta, 100 de escaneo y 16 IPs disponibles para monitorear (Figura 3), cifras que coinciden con la documentación (Shodan, s. f.-a). La clave de API permanece oculta en la captura. **Conclusión.** Con una cuenta gratuita alcanza para el laboratorio, siempre que se planifique el consumo.

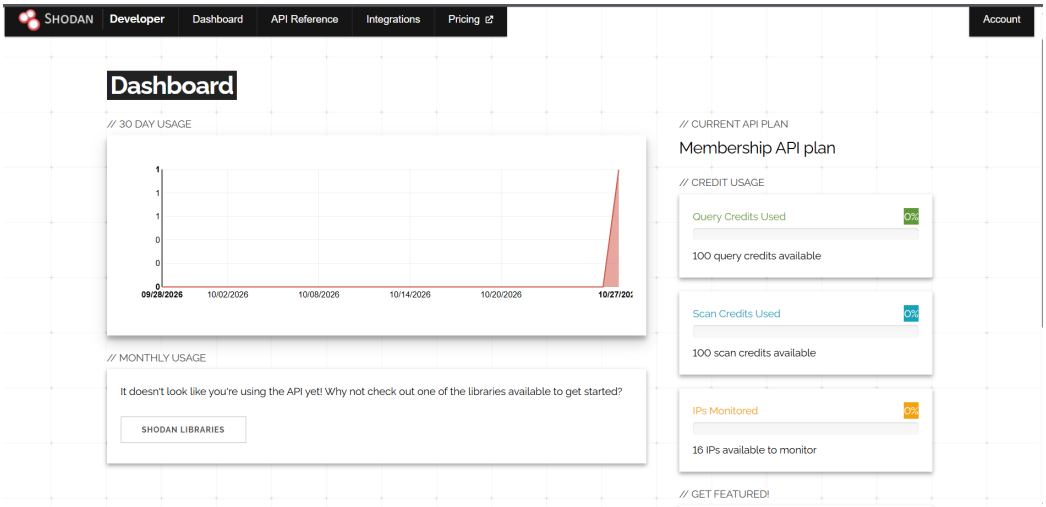
Figura 2
Resumen de la cuenta con nivel académico



Nota. Elaboración propia, 27 de octubre de 2026.

Figura 3

Panel de desarrollador con créditos disponibles



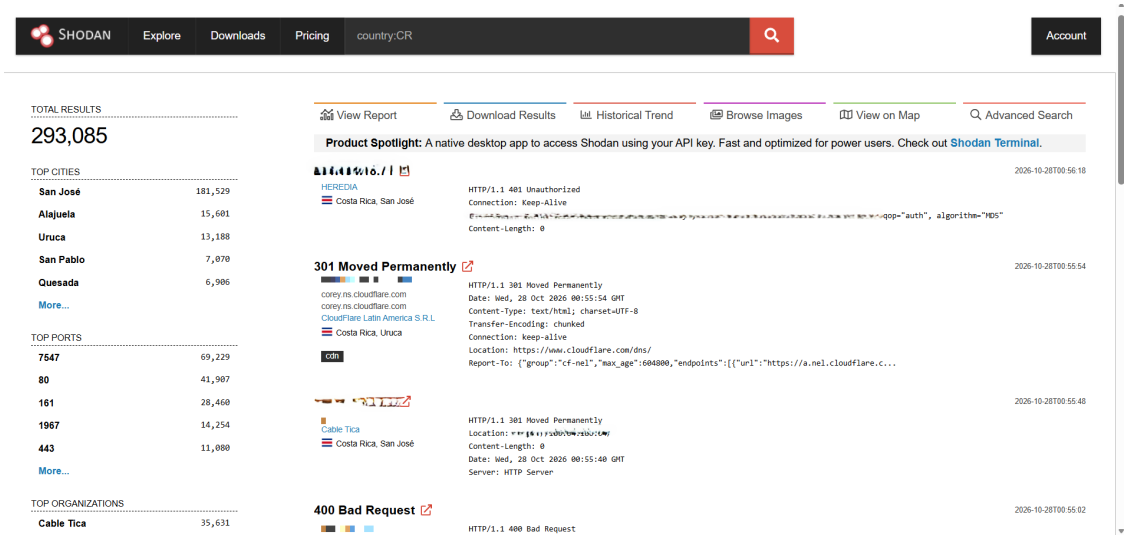
Nota. Elaboración propia, 27 de octubre de 2026.

Práctica 2: interfaz web y búsqueda por país

Objetivo. Ver cómo Shodan presenta un conjunto de resultados. **Filtro.** country:CR. **Resultado.** La búsqueda devolvió 293,085 resultados, con paneles laterales de ciudades, puertos y organizaciones más frecuentes (Figura 4). Los puertos principales fueron 7547 (69,229), 80 (41,907) y 161 (28,460). Cada resultado muestra IP, organización, ubicación, fecha de captura y el banner HTTP recibido. Por ética, las IP y datos de terceros se difuminaron. **Conclusión.** La interfaz web entrega, sin ningún cálculo, un primer mapa de lo expuesto.

Figura 4

Búsqueda country:CR en la interfaz web



Nota. Se difuminaron direcciones IP y nombres de host de terceros. Elaboración propia, 27 de octubre de 2026.

Práctica 3: Shodan CLI

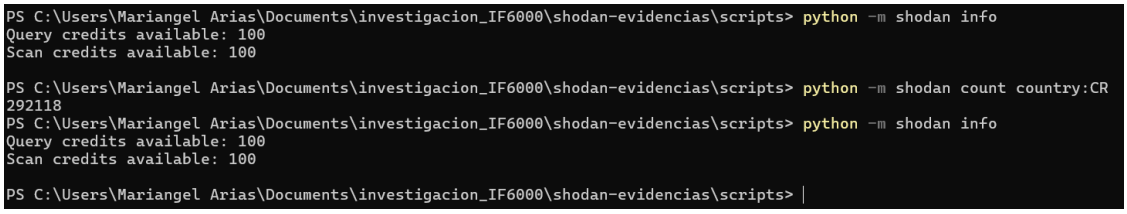
Prerrequisitos. Python y la biblioteca shodan instalados, y la clave inicializada con shodan init. En Windows la CLI se ejecutó como python -m shodan. **Comandos y resultados.**

python -m shodan info mostró 100 créditos de consulta y 100 de escaneo. python -m shodan count country:CR devolvió 292118 y no modificó los créditos (Figura 5). python -m shodan stats --facets port country:CR entregó los diez puertos más frecuentes, con 7547 (68,972), 80 (41,888) y 161 (28,448) a la cabeza (Figura 6). Para ver qué software corre en un puerto concreto usamos python -m shodan stats --facets product country:CR port:22: de 3,602 servicios SSH, 1,490 son OpenSSH (41.4 %), seguido de Dropbear (97) y Cisco SSH (22) (Figura 7).

Conclusión. La CLI permite obtener rankings en segundos y sin descargar resultados, que es justo lo que necesitábamos para un análisis agregado.

Figura 5

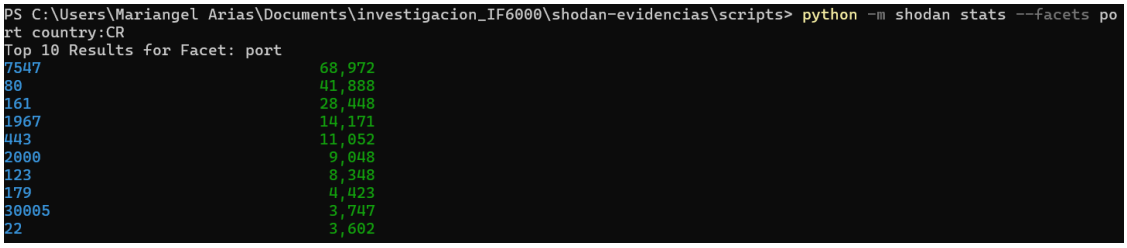
Comandos info y count en la CLI



Nota. Elaboración propia, 27 de octubre de 2026.

Figura 6

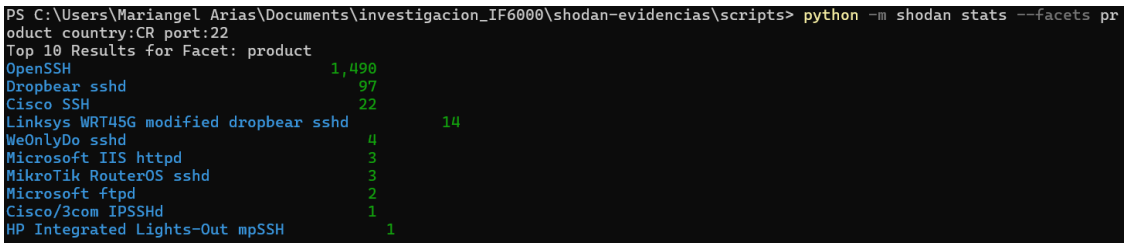
Puertos más frecuentes en country:CR con stats y facets



Nota. Elaboración propia, 27 de octubre de 2026.

Figura 7

Productos más frecuentes en el puerto 22 de Costa Rica



Nota. Elaboración propia, 27 de octubre de 2026.

Práctica 4: filtros de la interfaz web

Objetivo. Probar filtros más finos. Los filtros usados se resumen en la Tabla 3. La búsqueda country:CR port:22 devolvió 3,602 resultados y mostró que las organizaciones con más servicios SSH son NAVEGALO S.A. (662), RACKNATION S.A. (245) y Costa Rica Internet Service Provider S.A. (235) (Figura 8). La búsqueda country:CR product:nginx devolvió 6,128 resultados, con 1,218 en el puerto 80 y 972 en el 443 (Figura 10). Shodan etiqueta algunos resultados, por ejemplo eol-product para software fuera de soporte o self-signed para certificados autofirmados. Por último, country:CR ssl.cert.expired:true devolvió 2,399 resultados, con 1,616

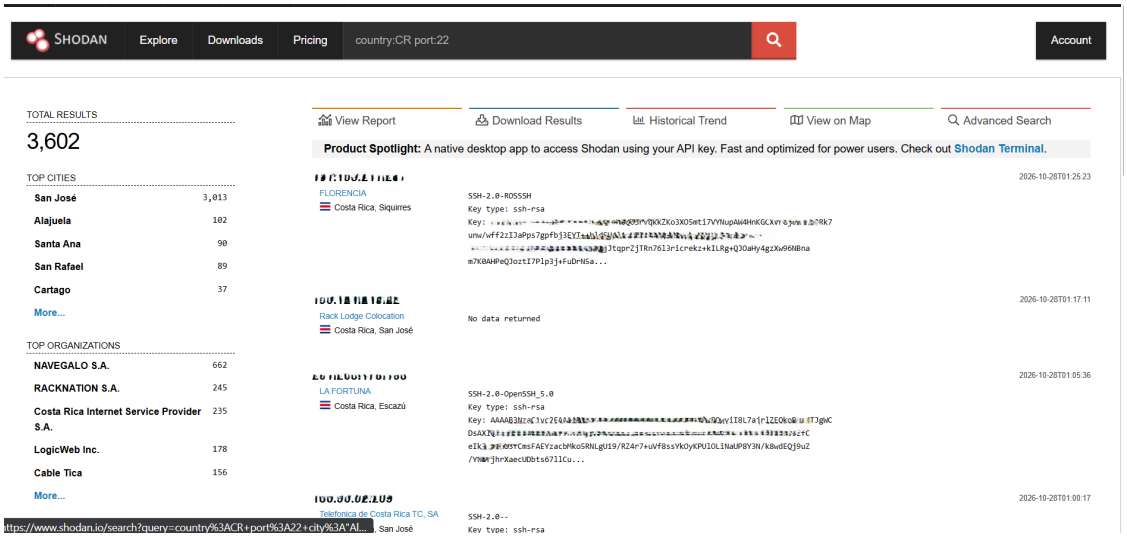
en San José (Figura 11). **Conclusión.** Combinar filtros convierte una pregunta vaga en un conteo verificable, y los facets laterales ya dan un análisis de segunda capa.

Tabla 3
Filtros y consultas utilizados

Consulta	Qué responde	Total observado
country:CR	Servicios indexados en Costa Rica	293,085 (web), 292,118 (CLI), 292,152 (script)
country:CR port:22	Servicios SSH en Costa Rica	3,602
country:CR product:nginx	Servicios que se identifican como nginx	6,128
country:CR ssl.cert.expired:true	Servicios con certificado TLS vencido	2,399

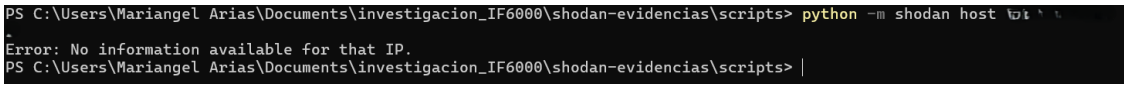
Nota. Elaboración propia con datos de Shodan, 27 de octubre de 2026. Los totales varían entre consultas porque el índice se actualiza continuamente.

Figura 8
Búsqueda country:CR port:22



Nota. Las direcciones IP ya aparecían ocultas. Elaboración propia, 27 de octubre de 2026.

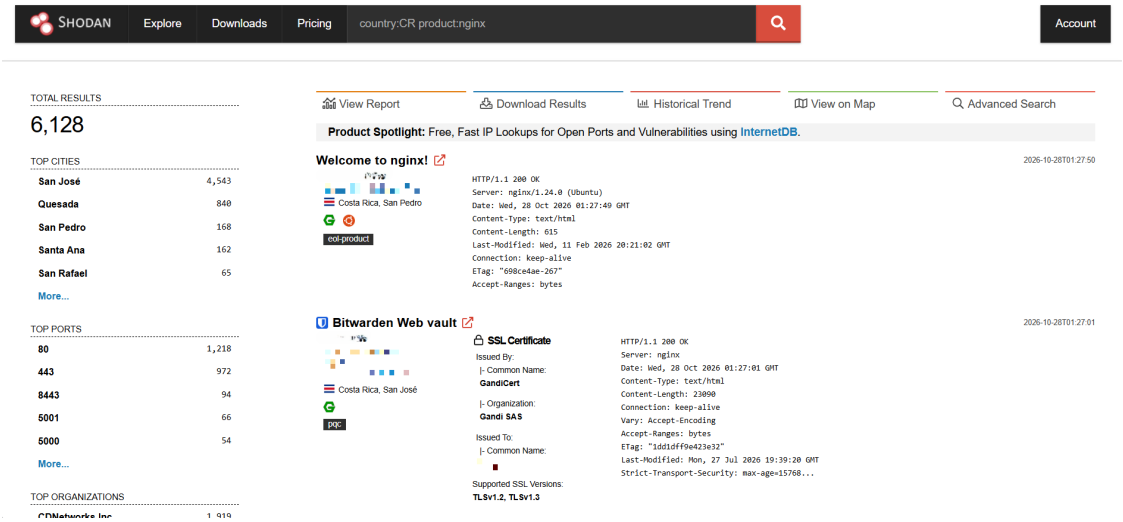
Figura 9
Consulta de una IP propia con la CLI: sin información en Shodan



Nota. La dirección IP se ocultó. El resultado es Error: No information available for that IP. Elaboración propia, 27 de octubre de 2026.

Figura 10

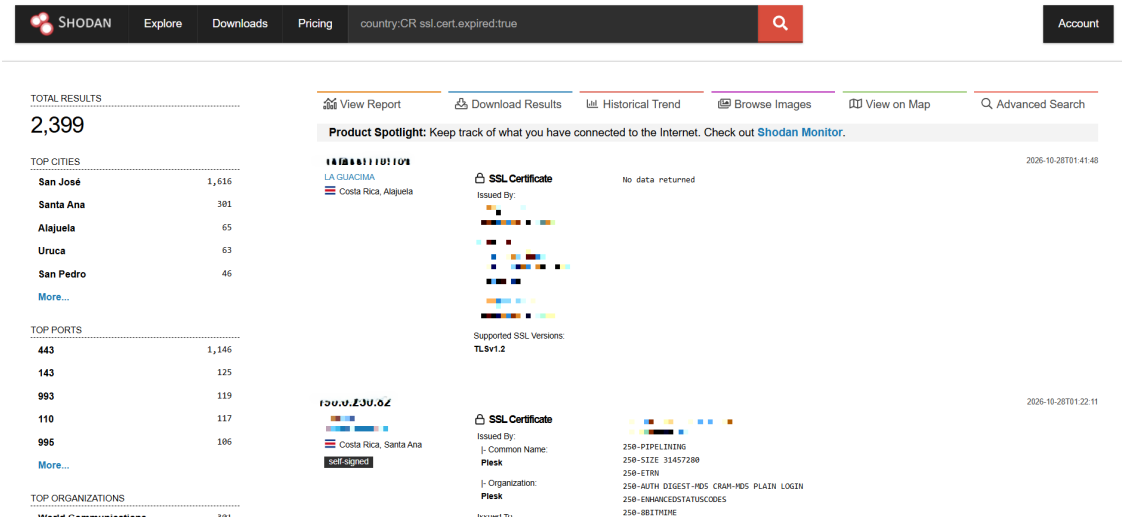
Búsqueda country:CR product:nginx



Nota. Se difuminaron datos de terceros. Elaboración propia, 27 de octubre de 2026.

Figura 11

Búsqueda country:CR ssl.cert.expired:true



Nota. Se difuminaron nombres de certificados y dominios de terceros. Elaboración propia, 27 de octubre de 2026.

Práctica 5: script propio con la API oficial

Objetivo. Automatizar el panorama de Costa Rica con un script en Python que use únicamente consultas de conteo con facets. **Diseño.** El script (Apéndice A) lee la clave de la variable de entorno o de la configuración de la CLI, nunca del código; consulta country:CR

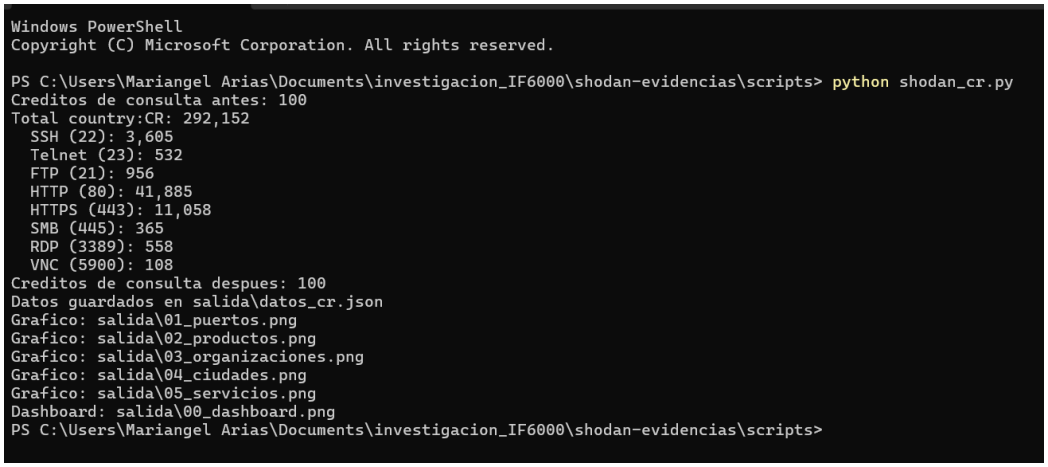
pidiendo facets de puerto, producto, organización, ciudad y sistema operativo; cuenta por separado ocho servicios comunes; respeta la pausa de un segundo entre solicitudes; guarda los datos en un JSON y genera gráficos con matplotlib. Incluye una opción --offline que regenera los gráficos desde el JSON, lo que sirve como respaldo si falla la red durante la demostración. El núcleo de la consulta es el siguiente:

```
api = shodan.Shodan(leer_key())
r = api.count(PAIS, facets=FACETS)        # total + rankings, sin hosts
datos['total'] = r['total']
for nombre, valores in r['facets'].items():
    datos['facets'][nombre] = [(v['value'], v['count']) for v in valores]
for etiqueta, filtro in SERVICIOS.items():
    time.sleep(PAUSA)
    datos['servicios'][etiqueta] = api.count(f'{PAIS} {filtro}')['total']
```

Resultado. La ejecución reportó 292,152 servicios, creó los datos y seis gráficos, y dejó los créditos en 100 antes y después (Figura 12). El panel resumen aparece en la Figura 13 y los gráficos individuales en las Figuras 14 a 18.

Figura 12

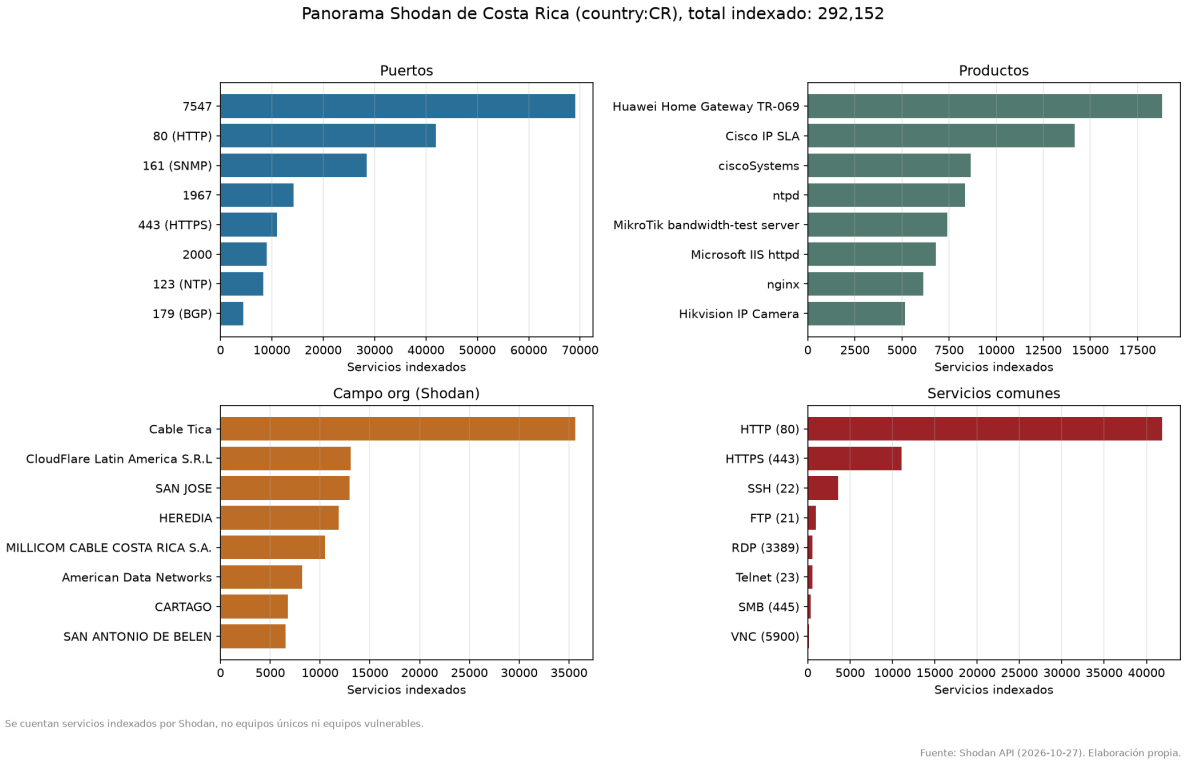
Ejecución del script shodan_cr.py



Nota. Elaboración propia, 27 de octubre de 2026.

Figura 13

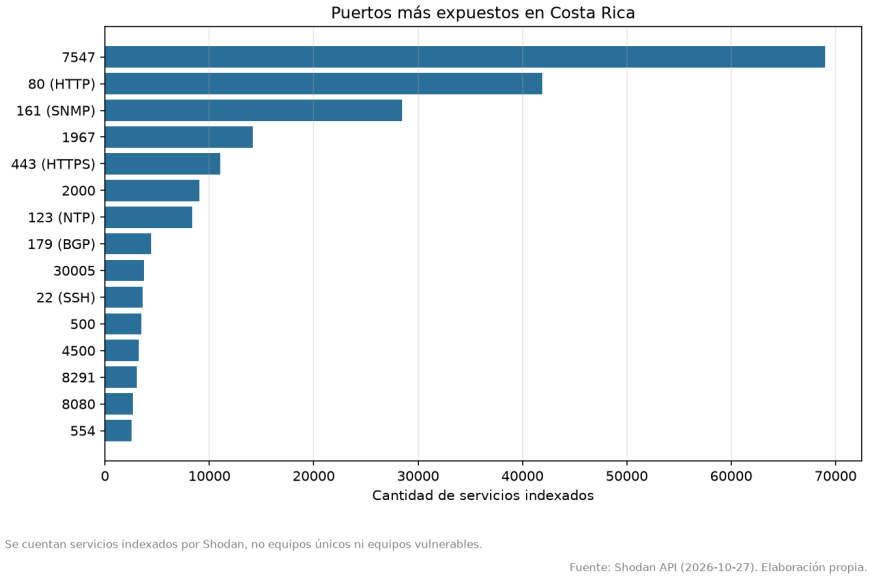
Panorama de Costa Rica generado con el script



Nota. Fuente: Shodan API, 27 de octubre de 2026. Se cuentan servicios indexados, no equipos únicos ni equipos vulnerables. Elaboración propia.

Figura 14

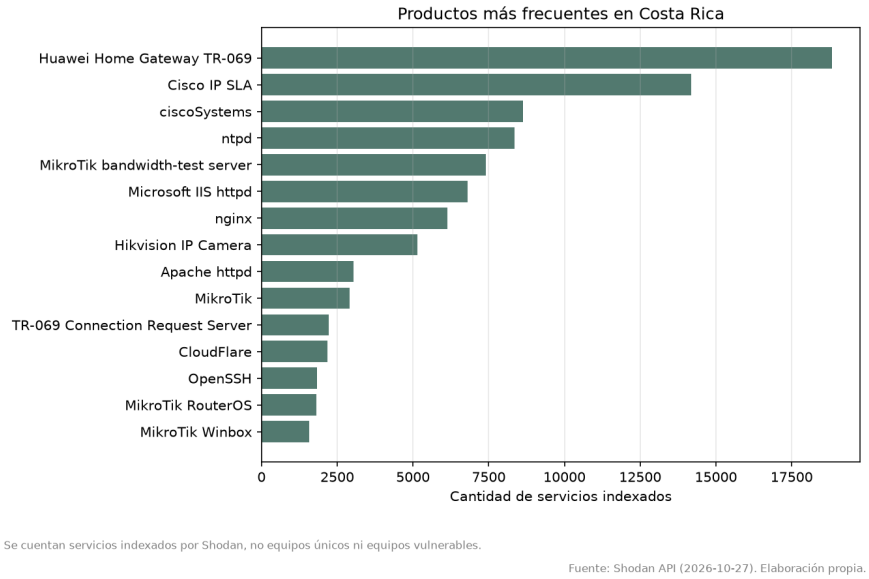
Puertos más expuestos en Costa Rica



Nota. Fuente: Shodan API. Elaboración propia, 27 de octubre de 2026.

Figura 15

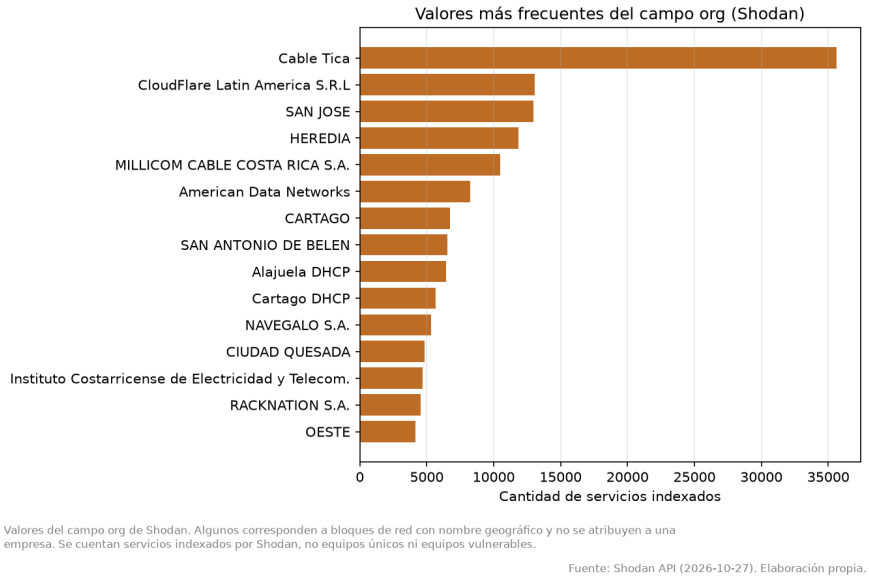
Productos más frecuentes en Costa Rica



Nota. Fuente: Shodan API. Elaboración propia, 27 de octubre de 2026.

Figura 16

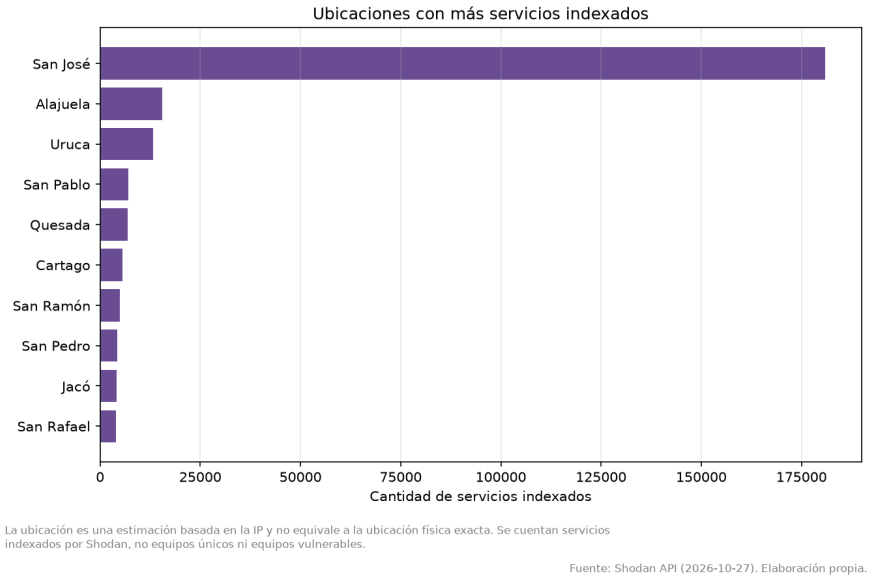
Valores más frecuentes del campo org



Nota. Algunos valores del campo org son bloques de red con nombre geográfico y no se atribuyen a una empresa. Elaboración propia, 27 de octubre de 2026.

Figura 17

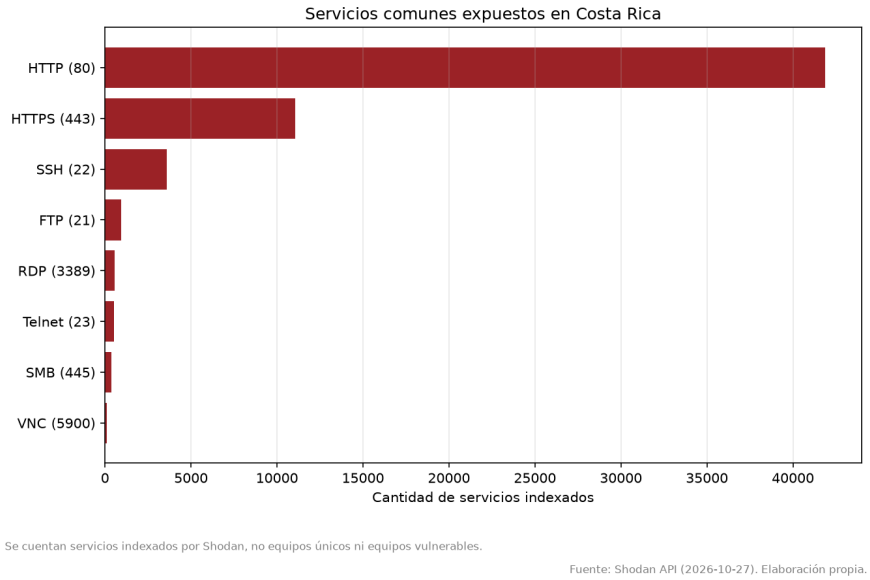
Ubicaciones con más servicios indexados



Nota. La ubicación es una estimación basada en la IP. Elaboración propia, 27 de octubre de 2026.

Figura 18

Servicios comunes expuestos en Costa Rica



Nota. Elaboración propia, 27 de octubre de 2026.

Hallazgos del panorama de Costa Rica

La Tabla 4 reúne los datos principales con su porcentaje sobre el total de 292,152 servicios. Los porcentajes son nuestros. Las interpretaciones que siguen son hipótesis razonables

a partir de los nombres de producto que reporta Shodan, y no se probaron contra ningún dispositivo.

Tabla 4
Principales resultados del panorama agregado de Costa Rica

Indicador	Valor	Cantidad	% del total
Puerto más frecuente	7547	69,018	23.6
Segundo puerto	80 (HTTP)	41,891	14.3
Tercer puerto	161 (SNMP)	28,450	9.7
Producto más frecuente	Huawei Home Gateway TR-069	18,825	6.4
Segundo producto	Cisco IP SLA	14,176	4.9
Campo org más frecuente	Cable Tica	35,612	12.2
Ubicación con más servicios	San José	180,890	61.9

Nota. Elaboración propia con datos de datos_cr.json (Shodan API, 27 de octubre de 2026). Se cuentan servicios indexados, no equipos únicos.

Tabla 5
Servicios comunes expuestos en Costa Rica

Servicio	Servicios indexados	Consulta
HTTP (80)	41,885	country:CR port:80
HTTPS (443)	11,058	country:CR port:443
SSH (22)	3,605	country:CR port:22
FTP (21)	956	country:CR port:21
RDP (3389)	558	country:CR port:3389
Telnet (23)	532	country:CR port:23
SMB (445)	365	country:CR port:445
VNC (5900)	108	country:CR port:5900

Nota. Elaboración propia con datos de Shodan API, 27 de octubre de 2026.

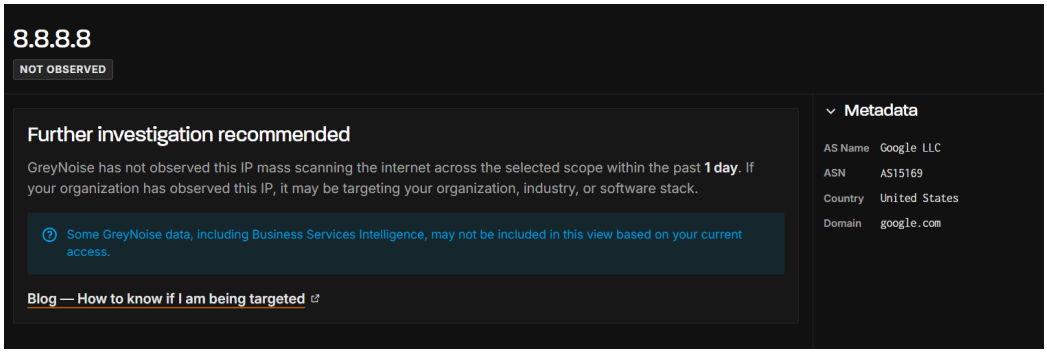
Primero, casi uno de cada cuatro servicios está en el puerto 7547 y los productos con TR-069 en el nombre suman miles; lo más probable es que correspondan a equipos de acceso a Internet de hogares gestionados por el proveedor, aunque esto es una hipótesis. Segundo, el puerto 161 (SNMP) aparece con 28,450 servicios, y los productos Cisco IP SLA y varios de MikroTik figuran entre los más frecuentes, lo que indica mucha infraestructura de red visible desde afuera. Tercero, los servicios HTTP indexados son 3.8 veces los HTTPS (41,885 frente a

11,058). Cuarto, los servicios de acceso remoto o archivos aparecen en cantidades menores pero no nulas: 3,605 SSH, 558 RDP, 532 Telnet y 365 SMB. Quinto, la concentración geográfica es fuerte: San José reúne el 61.9 %. Hay que leerlo con cuidado, porque la geolocalización por IP es una estimación y el campo org mezcla empresas con bloques de red con nombre geográfico. Que un servicio esté indexado no significa que sea vulnerable; para afirmar eso haría falta una evaluación autorizada, que está fuera del alcance.

Práctica 6: consulta de IP propia y contraste con GreyNoise

Objetivo. Comprobar qué sabe Shodan de una IP propia y comparar con una herramienta que mira el tráfico de escaneo. **Resultado.** python -m shodan host sobre una IP del grupo respondió que no hay información (Figura 9), es decir, Shodan no tenía servicios indexados de esa dirección. Luego consultamos en el GreyNoise Visualizer la IP pública 8.8.8.8, como ejemplo de servicio legítimo, y la IP propia del grupo. Ambas aparecen como NOT OBSERVED, es decir, GreyNoise no las observó escaneando masivamente Internet durante el último día, y su metadato indica el sistema autónomo y el país (Figuras 19 y 20). **Conclusión.** Cero resultados en Shodan significa que esa IP no figuraba en el índice, no que no tenga nada abierto, porque el índice no es exhaustivo.

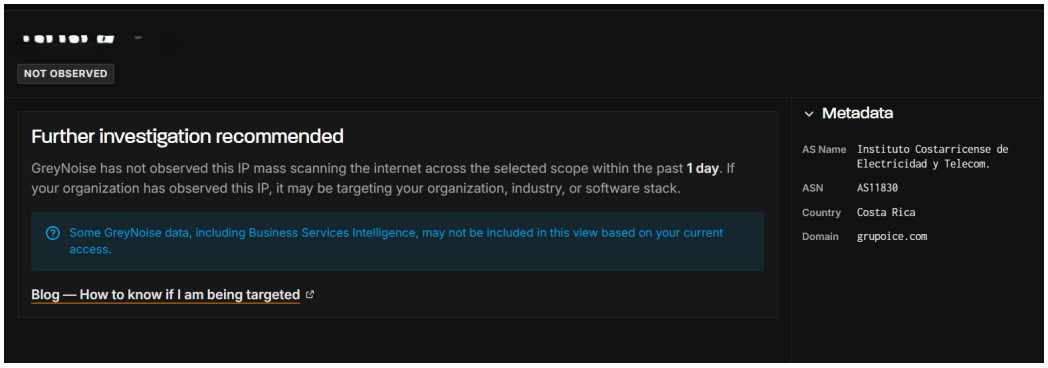
Figura 19
Consulta de 8.8.8.8 en GreyNoise Visualizer



Nota. GreyNoise muestra NOT OBSERVED y el metadato del sistema autónomo (Google LLC, AS15169). Elaboración propia, 27 de octubre de 2026.

Figura 20

Consulta de una IP propia en GreyNoise Visualizer



Nota. La dirección IP se ocultó. El metadato corresponde al Instituto Costarricense de Electricidad (AS11830). Elaboración propia, 27 de octubre de 2026.

Limitaciones

La consulta de una IP propia no devolvió información (Figura 9), así que no pudimos usarla para estudiar cómo Shodan muestra un equipo concreto. Tampoco se probó el escaneo bajo demanda (scan) ni Shodan Monitor, que solo se describen a partir de la documentación. Los datos son una fotografía del 27 de octubre de 2026 y cambiarán. Las cifras no se contrastaron con otra fuente independiente, y las interpretaciones sobre el puerto 7547 y los proveedores son hipótesis

Otros buscadores especializados

Shodan no es el único motor de este tipo. La Tabla 6 resume cuatro herramientas con lo que pudimos verificar en fuentes primarias. Solo GreyNoise se probó en la práctica.

Tabla 6

Comparación de buscadores y herramientas relacionadas

Herramienta	Qué es según la fuente	Diferencia o rasgo destacado	Probada
Censys	Motor de búsqueda respaldado por escaneo de Internet; usa ZMap para descubrir hosts y ZGrab para los handshakes de aplicación (Durumeric et al., 2015)	Permite búsqueda de texto completo, expresiones regulares y rangos numéricos sobre datos de los handshakes; ofrecía una interfaz pública de consulta en 2015 (afirmaciones de los autores)	No

Herramienta	Qué es según la fuente	Diferencia o rasgo destacado	Probada
ZoomEye	"Search engine of Internet-connected devices"; permite crear una cuenta gratuita (ZoomEye, s. f.)	Orientado a descubrimiento de activos, OSINT y pruebas de penetración; los límites del plan gratuito no se verificaron	No
FOFA	Motor de búsqueda del ciberespacio para localizar activos de red (FOFA, s. f.)	Ofrece búsqueda por ícono, búsqueda por lotes, documentación de API y sección de sintaxis	No
GreyNoise	Plataforma que estudia el ruido de Internet: el tráfico no solicitado (rastreadores, escáneres de puertos, investigadores) que reciben los equipos conectados; su red de sensores recopila paquetes de IPs vistas escaneando Internet (GreyNoise, s. f.)	Sirve para saber si una IP fue vista escaneando; su función RIOT informa sobre IPs de servicios empresariales comunes, para descartarlas como amenaza	Sí (Figuras 19 y 20)

Nota. Elaboración propia a partir de las fuentes citadas. Las afirmaciones sobre Censys corresponden a un artículo de 2015 y pueden haber cambiado.

La diferencia de fondo es de enfoque. Shodan, Censys, ZoomEye y FOFA responden a la pregunta de qué está expuesto; GreyNoise responde a la de quién está escaneando. Combinarlas da una imagen más completa: un servicio expuesto en Shodan cuya IP además aparece como escáner activo en GreyNoise merece más atención que uno que no lo hace. También conviene recordar que cada motor escanea desde sus propias IP y con sus propios criterios, de modo que los resultados no coinciden entre sí (Durumeric et al., 2015; Wu et al., 2024).

Información adicional importante

Marco ético y legal

Consultar el índice de Shodan es una consulta pasiva; conectarse a un dispositivo que aparece en él, probar contraseñas o interactuar con sus servicios es otra cosa y puede ser delito. En Costa Rica, la Ley 9048, de 7 de junio de 2012, reformó artículos y la sección de delitos informáticos y conexos del Código Penal; según la transcripción que consultamos, sus artículos incluyen la violación de correspondencia o comunicaciones (art. 196), la violación de datos personales (art. 196 bis) y el espionaje informático (art. 231) (Asamblea Legislativa de la

República de Costa Rica, 2012). No somos abogados y no analizamos el alcance de cada artículo; además, trabajamos con una transcripción de un sitio secundario, por lo que su texto debe verificarse en el sistema oficial de información jurídica antes de citarlo con otros fines.

En cuanto a los datos, la Ley 8968 define los datos personales como cualquier dato relativo a una persona física identificada o identificable (art. 3, inciso b) y establece la obligación de informar de previo a los titulares cuando se solicitan sus datos, dentro del principio de consentimiento informado (art. 5) (Asamblea Legislativa de la República de Costa Rica, 2011). Una dirección IP junto con otros datos podría identificar a una persona; si una IP concreta cuenta como dato personal es una cuestión jurídica que no resolvemos. Por prudencia, difuminamos las IP, dominios y nombres de organizaciones de terceros en las capturas y trabajamos con conteos agregados.

Hay además un debate ético sobre los propios motores. Wu et al. (2024) señalan falta de transparencia y de mecanismos para que los usuarios opten por no ser escaneados, así como prácticas que pueden publicar información personal y capturas de pantalla en los resultados. Es un recordatorio de que ser indexado no depende de la voluntad del dueño del equipo.

Cómo reducir la exposición

Con base en lo observado, las medidas más directas son: auditar periódicamente qué ve el exterior de la propia red, por ejemplo consultando las IP de la organización en Shodan; cerrar o restringir los servicios de administración (SSH, RDP, SNMP, Telnet) para que no queden abiertos a Internet; renovar los certificados vencidos, que en Costa Rica sumaban 2,399 servicios en nuestra consulta; y retirar software fuera de soporte, que Shodan marca con etiquetas como eol-product. Modificar los banners puede reducir la visibilidad en las consultas, como mostró la tesis de Bodenheim (2014) con dos controladores industriales (Bodenheim, 2014), pero no

sustituye al resto: según Wu et al. (2024), cambiar el puerto o bloquear IP de escáneres no evita ser escaneado. La propia plataforma ofrece Shodan Monitor para vigilar IP propias; el plan académico incluye hasta 16 (Shodan, s. f.-a), pero no la probamos.

Preparación de la demostración y respaldos

Como la exposición incluye una demostración en vivo, se dejaron respaldos: los datos de Costa Rica guardados en datos_cr.json, el modo --offline del script que regenera todos los gráficos sin conexión, y las capturas de este documento. Esto evita depender de la red o de los créditos durante la presentación.

Conclusiones

Las conclusiones se apoyan en hallazgos concretos del desarrollo.

1. Shodan indexa respuestas de servicios, no sitios. Lo comprobamos al ver que cada resultado muestra IP, puerto, organización, fecha y el banner recibido (Figura 4), y que los filtros operan sobre esos metadatos (Tabla 3).
2. Una cuenta académica gratuita basta para un análisis serio si se eligen bien las consultas. Con 100 créditos, el endpoint de conteo y los facets nos dieron 292,152 servicios, sus rankings y ocho conteos por servicio sin gastar un solo crédito (Figuras 3, 5 y 12).
3. La exposición de Costa Rica está concentrada. El puerto 7547 reúne el 23.6 % de los servicios indexados, San José el 61.9 % y un solo valor del campo org el 12.2 % (Tabla 4). Esa concentración sugiere que pocas decisiones de ISP pueden cambiar mucho el panorama, aunque esta lectura es una hipótesis que no probamos.
4. Un servicio indexado no es un servicio vulnerable. Las cifras de SSH, RDP, Telnet y SMB (Tabla 5) indican exposición, no debilidad, y afirmar lo segundo exigiría pruebas autorizadas que quedaron fuera del alcance.

5. El índice es una fotografía incompleta y cambiante. Los totales variaron el mismo día entre web, CLI y script (292,118; 292,152 y 293,085), y una IP propia no tenía información (Figura 9): no todo lo que está expuesto está indexado.
6. Ningún buscador basta por sí solo. GreyNoise respondió una pregunta distinta, quién escanea, y mostró que una IP legítima y una IP propia no figuraban como escáneres (Figuras 19 y 20). Combinar herramientas reduce el riesgo de leer mal un solo dato.
7. La ética es parte del método. Trabajar solo con conteos y difuminar datos de terceros nos permitió obtener todo lo anterior sin conectarnos a ningún dispositivo, y es la diferencia entre investigar y vulnerar.

En conjunto, Shodan es una herramienta de visibilidad: útil para defender si se usa para revisar la propia red, delicada si se usa sin criterio sobre la ajena.

Referencias

Asamblea Legislativa de la República de Costa Rica. (2011). *Ley N.° 8968: Protección de la persona frente al tratamiento de sus datos personales*. Superintendencia de Telecomunicaciones. https://www.sutel.go.cr/sites/default/files/normativas/ley_proteccion_de_la_persona_frente_al_tratamiento_de_sus_ley_8968.pdf

Asamblea Legislativa de la República de Costa Rica. (2012). *Ley N.° 9048: Reforma de varios artículos y modificación de la Sección VIII, denominada Delitos informáticos y conexos, del Título VII del Código Penal* [Transcripción]. Informática Jurídica. https://www.informatica-juridica.com/anexos/ley-no-9048-de-7-de-junio-de-2012-reforma-de-varios-articulos-y-modificacion-de-la-seccion-viii-denominada-delitos-informaticos-y-conexos-del-titulo-vii-del-codigo-penal/

Bodenheim, R. C. (2014). *Impact of the Shodan computer search engine on Internet-facing industrial control system devices* [Tesis de maestría, Air Force Institute of Technology]. AFIT Scholar. https://scholar.afit.edu/etd/590

Bodenheim, R., Butts, J., Dunlap, S., y Mullins, B. (2014). Evaluation of the ability of the Shodan search engine to identify Internet-facing industrial control devices. *International Journal of Critical Infrastructure Protection, 7*(2), 114-123. https://doi.org/10.1016/j.ijcip.2014.03.001

Durumeric, Z., Adrian, D., Mirian, A., Bailey, M., y Halderman, J. A. (2015). A search engine backed by Internet-wide scanning. En *Proceedings of the 2015 ACM SIGSAC Conference on Computer and Communications Security (CCS '15)*. ACM. https://doi.org/10.1145/2810103.2813703

FOFA. (s. f.). *FOFA* [Sitio web]. Recuperado el 19 de octubre de 2026, de https://en.fofa.info/

GreyNoise. (s. f.). *Glossary of terms*. Recuperado el 19 de octubre de 2026, de https://www.greynoise.io/glossary

Shodan. (s. f.-a). *Academic upgrade*. Shodan Help Center. Recuperado el 20 de octubre de 2026, de https://help.shodan.io/the-basics/academic-upgrade

Shodan. (s. f.-b). *Credit types explained*. Shodan Help Center. Recuperado el 18 de octubre de 2026, de https://help.shodan.io/the-basics/credit-types-explained

Shodan. (s. f.-c). *Installation*. Shodan Help Center. Recuperado el 18 de octubre de 2026, de https://help.shodan.io/command-line-interface/0-installation

Shodan. (s. f.-d). *Search query fundamentals*. Shodan Help Center. Recuperado el 18 de octubre de 2026, de https://help.shodan.io/the-basics/search-query-fundamentals

Shodan. (s. f.-e). *Shodan developer API*. Recuperado el 20 de octubre de 2026, de https://developer.shodan.io/api

Shodan. (s. f.-f). *What is Shodan?* Shodan Help Center. Recuperado el 19 de octubre de 2026, de https://help.shodan.io/the-basics/what-is-shodan

Wu, M., Hong, G., Chen, J., Liu, Q., Tang, S., Li, Y., Liu, B., Duan, H., y Yang, M. (2024). *Revealing the black box of device search engine: Scanning assets, strategies, and ethical consideration* [Preprint]. arXiv. https://arxiv.org/abs/2412.15696

ZoomEye. (s. f.). *ZoomEye* [Sitio web]. Recuperado el 20 de octubre de 2026, de https://www.zoomeye.ai/

Apéndice A

Script shodan_cr.py (código completo)

```
#!/usr/bin/env python3
"""
Panorama agregado de Costa Rica con la API oficial de Shodan.
IF-6000 Redes en los Negocios, UCR Sede de Occidente.

Solo usa shodan.count() con facets: devuelve totales y rankings agregados.
No obtiene IPs ni banners, no se conecta a ningun dispositivo.

Uso:
    python shodan_cr.py            # consulta Shodan y guarda datos + graficos
    python shodan_cr.py --offline  # regenera graficos desde datos_cr.json (respaldo)

La API key se lee de la variable SHODAN_API_KEY o, si no existe, de la misma
ubicacion que usa el CLI tras "shodan init". Nunca se escribe en el codigo.
"""
import argparse
import json
import os
import sys
import textwrap
import time
from datetime import datetime
from pathlib import Path

import matplotlib
matplotlib.use("Agg")
import matplotlib.pyplot as plt

PAIS = "country:CR"
SALIDA = Path("salida")
DATOS = SALIDA / "datos_cr.json"

# Facets de la consulta base: (nombre, cuantos valores pedir)
FACETS = [("port", 15), ("product", 15), ("org", 15), ("city", 10), ("os", 10)]

# Servicios sensibles de los que solo contamos cuantos hay expuestos.
SERVICIOS = {
    "SSH (22)": "port:22",
    "Telnet (23)": "port:23",
    "FTP (21)": "port:21",
    "HTTP (80)": "port:80",
    "HTTPS (443)": "port:443",
    "SMB (445)": "port:445",
    "RDP (3389)": "port:3389",
    "VNC (5900)": "port:5900",
}

# Solo puertos estandar (asignados por IANA). Los demas se muestran como numero.
PUERTOS_ESTANDAR = {
    "22": "SSH", "23": "Telnet", "21": "FTP", "80": "HTTP", "443": "HTTPS",
    "123": "NTP", "161": "SNMP", "179": "BGP", "445": "SMB", "3389": "RDP",
    "5900": "VNC",
}

NOTA_GENERAL = "Se cuentan servicios indexados por Shodan, no equipos únicos ni equipos
vulnerables."
NOTA_ORG = ("Valores del campo org de Shodan. Algunos corresponden a bloques de red con
nombre "
            "geográfico y no se atribuyen a una empresa. " + NOTA_GENERAL)
NOTA_CIUDAD = ("La ubicación es una estimación basada en la IP y no equivale a la ubicación
física "
               "exacta. " + NOTA_GENERAL)
```

```
PAUSA = 1.1  # la API permite 1 solicitud por segundo


def leer_key():
    key = os.environ.get("SHODAN_API_KEY")
    if key:
        return key.strip()
    # Misma funcion que usa el CLI de Shodan, asi siempre encuentra la key de "shodan init"
    try:
        from shodan.cli.helpers import get_api_key
        key = get_api_key()
        if key:
            return key.strip()
    except Exception:
        pass
    ruta = Path.home() / ".shodan" / "api_key"
    if ruta.exists():
        return ruta.read_text().strip()
    sys.exit("No hay API key. Ejecuta 'shodan init TU_KEY' o define SHODAN_API_KEY.")


def consultar():
    import shodan  # se importa aqui para que --offline funcione sin la libreria

    api = shodan.Shodan(leer_key())
    info = api.info()
    antes = info.get("query_credits")
    print(f"Creditos de consulta antes: {antes}")

    datos = {"fecha": datetime.now().isoformat(timespec="seconds"),
             "consulta_base": PAIS, "creditos_antes": antes,
             "total": None, "facets": {}, "servicios": {}}

    # 1) Consulta base con todos los facets
    try:
        r = api.count(PAIS, facets=FACETS)
        datos["total"] = r["total"]
        for nombre, valores in r.get("facets", {}).items():
            datos["facets"][nombre] = [(v["value"], v["count"]) for v in valores]
        print(f"Total {PAIS}: {datos['total']:,}")
    except shodan.APIError as e:
        sys.exit(f"Error en la consulta base: {e}")

    # 2) Conteo por servicio sensible
    for etiqueta, filtro in SERVICIOS.items():
        time.sleep(PAUSA)
        try:
            datos["servicios"][etiqueta] = api.count(f"{PAIS} {filtro}")["total"]
            print(f"  {etiqueta}: {datos['servicios'][etiqueta]:,}")
        except shodan.APIError as e:
            print(f"  {etiqueta}: error ({e})")

    datos["creditos_despues"] = api.info().get("query_credits")
    print(f"Creditos de consulta despues: {datos['creditos_despues']}")

    SALIDA.mkdir(exist_ok=True)
    DATOS.write_text(json.dumps(datos, ensure_ascii=False, indent=2), encoding="utf-8")
    print(f"Datos guardados en {DATOS}")
    return datos


def etiquetar_puertos(pares):
    """Agrega el nombre del servicio solo a puertos estandar."""
    salida = []
    for valor, cuenta in pares or []:
        nombre = PUERTOS_ESTANDAR.get(str(valor))
        salida.append((f"{valor} ({nombre})" if nombre else str(valor), cuenta))
    return salida
```

```
def pie(fig, fecha, nota=None):
    fig.text(0.99, 0.01, f"Fuente: Shodan API ({fecha}). Elaboración propia.",
             ha="right", fontsize=8, color="gray")
    if nota:
        fig.text(0.01, 0.045, "\n".join(textwrap.wrap(nota, 120)),
                 ha="left", va="bottom", fontsize=8, color="gray")


def barras(titulo, pares, archivo, color, fecha, nota=NOTA_GENERAL):
    if not pares:
        return
    etiquetas = [str(p[0]) for p in pares]
    valores = [p[1] for p in pares]
    fig, ax = plt.subplots(figsize=(9, 6))
    ax.barh(etiquetas[::-1], valores[::-1], color=color)
    ax.set_xlabel("Cantidad de servicios indexados")
    ax.set_title(titulo)
    ax.grid(axis="x", alpha=0.3)
    pie(fig, fecha, nota)
    fig.tight_layout(rect=[0, 0.1, 1, 1])
    fig.savefig(SALIDA / archivo, dpi=150)
    plt.close(fig)
    print(f"Grafico: {SALIDA / archivo}")


def graficar(d):
    fecha = d["fecha"][:10]
    f = d["facets"]
    puertos = etiquetar_puertos(f.get("port"))
    servicios = sorted(d.get("servicios", {}).items(), key=lambda x: x[1], reverse=True)

    barras("Puertos más expuestos en Costa Rica", puertos, "01_puertos.png", "#2a6f97",
fecha)
    barras("Productos más frecuentes en Costa Rica", f.get("product"), "02_productos.png",
"#52796f", fecha)
    barras("Valores más frecuentes del campo org (Shodan)", f.get("org"),
"03_organizaciones.png",
           "#bc6c25", fecha, NOTA_ORG)
    barras("Ubicaciones con más servicios indexados", f.get("city"), "04_ciudades.png",
           "#6a4c93", fecha, NOTA_CIUDAD)
    barras("Servicios comunes expuestos en Costa Rica", servicios, "05_servicios.png",
"#9b2226", fecha)

    # Panel resumen para la demo
    fig, ejes = plt.subplots(2, 2, figsize=(14, 9))
    paneles = [("Puertos", puertos, "#2a6f97"),
               ("Productos", f.get("product"), "#52796f"),
               ("Campo org (Shodan)", f.get("org"), "#bc6c25"),
               ("Servicios comunes", servicios, "#9b2226")]
    for ax, (nombre, pares, color) in zip(ejes.flat, paneles):
        pares = (pares or [])[:8]
        ax.barh([str(p[0]) for p in pares][::-1], [p[1] for p in pares][::-1], color=color)
        ax.set_title(nombre)
        ax.set_xlabel("Servicios indexados")
        ax.grid(axis="x", alpha=0.3)
    total = d.get("total")
    fig.suptitle(f"Panorama Shodan de Costa Rica ({PAIS}), total indexado: {total:,}" if
total
                 else "Panorama Shodan de Costa Rica", fontsize=14)
    pie(fig, fecha, NOTA_GENERAL)
    fig.tight_layout(rect=[0, 0.07, 1, 0.96])
    fig.savefig(SALIDA / "00_dashboard.png", dpi=150)
    plt.close(fig)
    print(f"Dashboard: {SALIDA / '00_dashboard.png'}")


if __name__ == "__main__":
```

```
    ap = argparse.ArgumentParser()
    ap.add_argument("--offline", action="store_true", help="usar datos_cr.json en vez de
consultar Shodan")
    args = ap.parse_args()

    if args.offline:
        if not DATOS.exists():
            sys.exit(f"No existe {DATOS}. Corre primero sin --offline.")
        datos = json.loads(DATOS.read_text(encoding="utf-8"))
    else:
        datos = consultar()
    graficar(datos)
```

Apéndice B

Índice de evidencias

Tabla 7

Figuras del documento y archivo de evidencia

Figura	Contenido	Archivo
1	Flujo simplificado de funcionamiento	diag_funcionamiento.png
2	Cuenta académica	01a-cuenta-academica.png
3	Panel de créditos	01b-creditos.png
4	Búsqueda country:CR (web)	02-primera-busqueda.png
5	CLI: info y count	04-creditos-busqueda.png
6	CLI: facets de puerto	05-puertos-recientes.png
7	CLI: productos en el puerto 22	06-cli-ssh-productos.png
8	Web: country:CR port:22	09-filtro-puerto.png
9	CLI: host de IP propia sin información	08-host-ip-propia.png
10	Web: product:nginx	10-filtro-producto.png
11	Web: certificados vencidos	11-filtro-certificados.png
12	Ejecución del script	03-script-ejecucion.png
13 a 18	Dashboard y cinco gráficos	salida/00_dashboard.png y 01 a 05
19	GreyNoise: 8.8.8.8	12-servicio-legitimo.png
20	GreyNoise: IP propia	13-servicio-propio.png

Nota. Las capturas de las Figuras 4, 10 y 11 se publican con datos de terceros difuminados; los originales se conservan solo en el repositorio del grupo.